A2: Projekt

Aufgabenbeschreibung

Im Projekt wendet ihr das erlangte Wissen der ILV an und erweitert dieses durch selbstständige Recherche. Ihr könnt die Richtung (um welche Anwendung es sich handelt – gerne auch etwas aus eurem beruflichen Umfeld) des Projektes selbstständig wählen. Folgende Anforderungen müssen jedoch für diese fiktive Anwendung erfüllt sein:

- Microservice Architektur
- Mindestens 3 Microservices
- Mindestens einen Anwendungsfall, welcher eine Transaktion über mehrere Microservices durchführt unter Betrachtung des Fault Tolerance Aspekts
- Es muss ein Frontend vorgesehen werden (bspw. User Interface oder API)
- Es muss ein Backend Mircoservice vorgesehen werden

Gruppenarbeit besteht aus **zwei** Liefergegenständen:

1. Liefergegenstand – Prototyp & Report:

Es muss ein Prototyp erstellt werden, welcher zumindest eine Funktionalit der fiktiven Anwendung abbildet. Die Erstellung des Codes bzw. etwaiger Konfiguration kann mit AI basierten Systemen erfolgen. Der Prototyp muss auf Basis von Docker erzeugt werden und eine Anleitung zum Starten muss entsprechend in der Abgabe bereitgestellt werden.

Der Report soll 3000 Wörter +/-10% besitzen und darf maximal 12 Seiten umfassen. (normaler Zeilenabstand – Schriftgröße 10 – Word Default Seitenränder!)

Alle Diagramme, Skizzen, etc. welche für die Bewertung notwendig sind müssen sich in diesen 12 Seiten befinden. Ein Anhang kann erstellt werden, wird aber nicht bewertet. Deckblatt, Inhaltsverzeichnis und Literaturverzeichnis werden nicht gezählt.

Die Struktur des Reports und die geforderten Inhalte werden im Kapitel „Struktur und Bewertung des Reports“ auf der zweiten Seite dieser Angabe beschrieben.

Der finale Report umfasst bis zu 60% der Gesamtnote der PT.

Der Zwischenreport wird nicht separat benotet. Nichtsdestotrotz ist die Ausarbeitung und zeitgerechte Abgabe der Inhalte bis zum Abgabetermin des Zwischenreports relevant, um Feedback zu erhalten und trägt deshalb bis zu 5% der Benotung des finalen Reports bei.

2. Liefergegenstand – Präsentation (=A3):

Die finale Präsentation soll das gewählte (Implementierungs-) Projekt vorstellen und die wesentlichsten Aspekte aufzeigen. Dazu soll die Struktur des Reports beibehalten werden:

- Einleitung & Beschreibung der Domain und des Vorhabens.
- Threat Modeling
- Security Konzept
- Security Testing
- Diskussion
- Ergebnis / Zusammenfassung

Erfüllung der optionalen Erweiterungen (bspw. Live-Demo)

Die Präsentation darf 15 Minuten nicht überschreiten. Die Zeit wird gestoppt und nach überschreiten der Zeit wird die Präsentation abgebrochen.

Die Präsentation umfasst bis zu 15% der Gesamtnote der PT.

Bewertung des Prototypen und Reports

Bewertung des Protypen

Der im Rahmen dieses Projektes entwickelte Prototyp wird wie folgt bewertet:

Liefergegenstand	Punkte
Anleitung zum Starten des Prototypen. Die Anleitung muss alle Schritte umfas um den Prototypen zu starten	5
Source Code (inklusive ordentlicher Kommentare) und Konfigurationen des entwickelten Prototypen.	10
Maximale Punkte	15

Optionale Challenges:

Folgende Challenges sollten im Zuge des Projekts bewältigt werden.

Die Challenges sind nicht verpflichtend, tragen aber insgesamt mit 10 Punkten zur Gesamtpunkteanzahl des Projektes bei.

Erweiterung	Liefergegenstand	Punkte
1	Praktische Anwendung ausgewählter Sicherheitsmaßnahmen (WAF und Authentifizierung) auf Basis der entwickelten Anwendung. Ein entsrpechender Verweis auf die Implementierung muss im Report entsprechend dargestellt werden. (Kapitel Security Konzept)	5
2	Praktische Anwendung SAST, SCA und DAST auf die entwickelte Microservice Anwendung. Die Ergebnisse der Anwendung sind der Liefergegenstand und müssen im Report entsprechend diskutiert bzw. dargestellt werden. (Kapitel Security Testing)	5
	Maximale Punkte der Challenges	10

Die Dokumentation der Challenges trägt nicht zur maximalen Seiten- bzw. Wörteranzahl bei.

Struktur und Bewertung des Reports

Die Bewertung des Reports erfolgt anhand folgender Struktur (Diese muss eingehalten werden):

Kapitel	Inhalt	Punkte[1]
Einleitung	Beschreibung der Aufgabenstellung und der Vorgehensweise	2
	Erstellung der Zielarchitektur inkl. Diagramme (Architekturdiagramm, Datenflussdiagramm) sowie Beschreibung der Business Prozesse für diese Anwendung	15
	Definition von funktionalen Anforderungen für die Anwendung	2
	Beschreibung eines mikroserviceübergreifenden Testfalls (Fault Tolerance).	2
Threat Modeling	Kleiner Literaturreview: Vergleich unterschiedlicher Threat Modeling Frameworks	7
	Durchführung des Threat Modelings und ableiten von Sicherheitsmaßnahmen für die entworfene Anwendung mittels PASTA (etwaige fehlende Informationen für PASTA müssen entsprechend im Einleitungskapitel ergänzt werden)	12
Security Konzept	Erstellung eines nachvollziehbaren Security Konzepts auf Basis der Sicherheitsanforderungen.	10
	(Wenn optionale Challenge #1 durchgeführt) Dokumentation der Umsetzung von Security Maßnahmen aus dem Security Konzept im Prototyp. (Kein Code sonder Beschreibung & Verweise)	
	Kleiner Literaturreview: Welche Herausforderungen hinsichtlich Security Incident Response bestehen in MSA?	7
Security Testing	Konzeptionierung der unterschiedlichen Testmöglichkeiten SAST, DAST, SCA sowie Penetration Tests für den Entwicklungsprozess der fiktiven Anwendung.	8
	(Wenn optionale Challenge #2 durchgeführt) Diskussion der Ergebnisse aus den angewendeten Security Tests.	
Diskussion	Welche Herausforderungen sind aufgetreten und wie konnten diese bewältigt werden?	5
Ergebnis / Zusammenfassung		5
Aufbereitung, Schreibstil und Referenzen		5
Zeitgerechte Zwischenabgabe		5
	Maximale Punkte	85

[1] Stellt die maximal zu erreichende Punkteanzahl dar. Die Punkteanzahl soll auch als Indikation für den Umfang des jeweiligen Inhaltes dienen.

Gesamtbewertung

Die folgende Tabelle stellt eine Übersicht über die zuvor dargestellten Bewertungskriterien dar:

Bewertungsgegenstand	Max. Punkte
Protypen	15
Report	85
Maximale Punkte	**100**
(**Optional**) **Challenges**	10

Jeder Bewertungsgegenstand muss Posititive sein, um eine positive Gesamtbewertung zu erhalten.